

UNC6671 SCRIPTED FILE ACCESS

Hunt for SharePoint or OneDrive file access performed through scripting clients observed in cloud data-theft operations.

HUNTING QUERY

CONFIDENCE: MEDIUM

SOURCE-CONFIRMED BEHAVIOR

retain facts, isolate interpretation

OfficeActivity

direct telemetry boundary

HUNT · VALIDATE · TUNE

no automatic malicious verdict

REPORT DATE

08 August 2026

VERSION

v1.0

PRIMARY TELEMETRY

Microsoft Sentinel ·
OfficeActivity

ATT&CK

T1213.002

Evidence-led dossier. Query status remains an untested implementation sketch until executed in the target environment.

INDEPENDENT RESEARCH FORMAT · CONTROLLED UI/UX MASTER

01

EXECUTIVE ASSESSMENT

Decision-grade summary for detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

Hunt scripted access without claiming exfiltration.

GTIG reports automated Microsoft 365 data theft and explicitly recommends treating FileAccessed as seriously as FileDownloaded when UserAgent identifies scripting clients. The hunt retains only the documented access event and source-observed client families.

OPERATIONAL VALUE

Direct SaaS visibility after identity compromise.

The query can expose programmatic collection that bypasses browser-centric review while preserving user, client IP, resource and device context. It avoids an arbitrary volume threshold and does not depend on short-lived phishing infrastructure.

9.1

01

OPERATIONAL VALUE



Medium

02

DETECTION CONFIDENCE



Hunting

03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACTS

Observed behavior

- UNC6671 uses AiTM phishing and persistent sessions before automated SaaS data theft.
- GTIG observed python-requests/2.28.1 and WindowsPowerShell/5.1 user agents.
- GTIG also recommends monitoring Go-http-client as a scripting-library class.

ANALYTICAL ASSESSMENT

What the evidence supports

- FileAccessed plus a scripting UserAgent is a strong collection lead, not proof of download.
- The behavior survives rapid rotation of phishing domains and residential proxies.
- Approved integrations and automation are the principal benign overlap.

DETECTION ASSUMPTIONS

What must be validated

- The Microsoft 365 connector ingests SharePoint and OneDrive audit activity.
- UserAgent is populated for the relevant FileAccessed events.
- Approved scripting clients can be mapped to stable owners and service accounts.

Confidence boundary

Microsoft documents five-minute suppression for repeated FileAccessed events on the same user and file. A match cannot establish bytes transferred, bulk volume, sensitive content or UNC6671 attribution.

02

THREAT MECHANICS

Source-observed chain and explicit observability boundaries.

ATTACK FLOW

01

Vishing pretext

A caller impersonates IT and directs the employee to a lookalike passkey portal.

02

AiTM session theft

The panel captures credentials and MFA/session material.

03

Session persistence

The actor accesses enterprise SaaS applications.

04

Scripted collection

Automation accesses SharePoint or OneDrive files.

05

Data theft extortion

Collected cloud data supports extortion operations.

Observable core

A Microsoft 365 audit event where Operation is FileAccessed and UserAgent begins with python-requests/, WindowsPowerShell/ or Go-http-client/.

Non-observable boundary

Call content, credential entry, token theft, response bodies, bytes transferred, file sensitivity and successful exfiltration.

DETECTION HYPOTHESIS

Programmatic collection should retain its client identity in audit telemetry.

If an attacker automates SharePoint or OneDrive collection through the documented scripting clients, OfficeActivity should show FileAccessed with the corresponding UserAgent. Approved application ownership, service-account use, ClientIP, managed-device state and resource scope distinguish legitimate automation.

REQUIRED TELEMETRY

OfficeActivity

- Microsoft 365 audit events in OfficeActivity.
- Operation and UserAgent.
- UserId, ClientIP and resource identifiers.

OPTIONAL ENRICHMENT

Context that improves disposition

- Service-account and application inventory.
- Conditional Access and sign-in telemetry.
- Sensitivity labels and data owner context.

UNAVAILABLE HERE

Do not infer

- Request or response body.
- Bytes transferred or download completion.
- Vishing and AiTM proof from this event.



TELEMETRY & EVIDENCE MODEL

Minimum data contract and quality gates for a defensible hunt.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Sentinel - OfficeActivity

The Microsoft 365 connector populates OfficeActivity with audit operations, user, client IP, UserAgent and SharePoint/OneDrive resource context.

EVIDENCE BOUNDARY

A matching event is a lead, not a verdict.

FileAccessed means a user or system account accessed a file. Microsoft may suppress repeated access events for the same user and file for five minutes.

REQUIRED AND ENRICHMENT FIELD MODEL

CATEGORY	FIELD	PURPOSE	REQUIREMENT
Audit event	OfficeActivity	Primary Microsoft 365 activity.	REQUIRED
Action	Operation	Exact FileAccessed event.	REQUIRED
Client	UserAgent	Scripting-client discriminator.	REQUIRED
Identity	UserId, UserType	Actor and account-class pivot.	REQUIRED
Network	ClientIP	Session and proxy pivot.	REQUIRED
Resource	Site_Url, SourceRelativeUrl, SourceFileName	Accessed object context.	REQUIRED
Device	IsManagedDevice	Optional trust enrichment.	OPTIONAL
Event identity	TimeGenerated, OfficeId	Raw-event pivot.	REQUIRED

Data quality requirements

- Confirm the Microsoft 365 connector covers SharePoint and OneDrive.
- Measure UserAgent population for FileAccessed.
- Preserve raw audit records and OfficeId.
- Inventory approved scripting integrations and service accounts.

Known failure conditions

- UserAgent is empty or normalized differently.
- Activity predates audit retention.
- Attackers use a browser-like or custom UserAgent.
- Approved automation lacks reliable ownership metadata.



DETECTION LOGIC

Primary-platform logic with every condition traceable to evidence.

HUNTING QUERY

DETECTION OBJECTIVE

Find source-supported programmatic file access.

Select FileAccessed events generated by scripting client families named in GTIG guidance and retain sufficient investigation context.

ANALYTICAL LOGIC

Direct filters and investigable output.

One exact operation and three direct UserAgent prefixes; no IOC, join, threshold, aggregation, rarity, volume claim or automatic attribution.

KQL · UNTESTED HUNT

```
// UNC6671 - scripted SharePoint or OneDrive file access
// Classification: Hunting query - Untested implementation sketch
// Confidence: Medium
// Primary platform: Microsoft Sentinel / Log Analytics
// Telemetry: Microsoft 365 connector -> OfficeActivity
//
// GTIG recommends treating FileAccessed as seriously as FileDownloaded when
// UserAgent identifies a scripting library. FileAccessed records access, not
// confirmed download or exfiltration. Validate every match against approved
// automation, service ownership, user/session context and accessed resources.

OfficeActivity
| where Operation == "FileAccessed"
| where UserAgent startswith "python-requests/"
  or UserAgent startswith "WindowsPowerShell/"
  or UserAgent startswith "Go-http-client/"
| project TimeGenerated,
  UserId,
  UserType,
  ClientIP,
  UserAgent,
  OfficeWorkload,
  Site_Url,
  SourceRelativeUrl,
  SourceFileName,
  OfficeObjectId,
  IsManagedDevice,
  ResultStatus,
  OfficeId
| order by TimeGenerated desc
```

REVIEW FIELDS · BASELINE LOCALLY · VALIDATE BEFORE PRODUCTION

STATUS	THRESHOLD	JOIN / SEQUENCE	PRIMARY KEY	DISPOSITION
Untested hunt	None	None	Officeld	Manual triage

What a match means

A scripting client accessed a SharePoint or OneDrive file under an identified account and requires ownership and session validation.

What a match does not prove

File download, bulk collection, sensitive content, successful exfiltration, malicious intent or UNC6671 attribution.



TRIAGE & INVESTIGATION

Evidence collection before escalation.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

Confirm the raw audit event.
Verify Operation, UserAgent, user, IP, resource and Officeld.
- 02

Establish automation ownership.
Map the account and client to an approved integration, runbook or change record.
- 03

Review identity context.
Inspect sign-ins, device trust, MFA changes, session controls and residential/VPN origin.
- 04

Scope resource access.
Identify sites, files, labels and data owners touched by the same session.
- 05

Assess follow-on.
Search for password resets, deleted security notifications and additional SaaS collection.

Escalation gate

Escalate when the client is unowned, the account is interactive or privileged, the origin/session is unexplained, and accessed resources or adjacent audit activity indicate unauthorized collection.

Primary benign overlap

Backup, migration, eDiscovery, governance, DLP, indexing and business integrations can use the same libraries. Tune through verified application, account, owner and bounded network context; never suppress a UserAgent globally.

INVESTIGATION PIVOTS

Identity
Account role, owner and authentication timeline.

Session
IP, device trust and Conditional Access.

Client
Exact UserAgent and approved integration.

Resource
Site, path, file and sensitivity label.

Audit
Neighboring FileAccessed and FileDownloaded events.

Control plane
MFA, password-reset and notification activity.

DISPOSITION CRITERIA

OUTCOME	MINIMUM EVIDENCE	ACTION
BENIGN	Approved, owned and repeatable activity.	Document and tune narrowly.
SUSPICIOUS	Unknown activity without corroborated malicious follow-on.	Deepen endpoint review.
LIKELY MALICIOUS	Unauthorized match plus coherent file, process, network or control-plane evidence.	Escalate incident response.



FALSE POSITIVES & VALIDATION

Operational controls required before promotion.

QUALITY GATE

FALSE-POSITIVE MATRIX

SCENARIO	WHY IT OVERLAPS	TUNING ACTION
Approved integration	Automation may read SharePoint files with Python, PowerShell or Go.	Require owner, service account, expected sites and run schedule.
Backup or migration	Bulk access is inherent to the workflow.	Use platform identity, change record and bounded source ranges.
Security or compliance tooling	DLP, eDiscovery or IR may inspect files.	Validate case, operator and approved application context.

Baseline plan

- Run across 30-90 days.
- Classify every matching account and client.
- Map stable sites, schedules and source ranges.
- Measure missing UserAgent and audit suppression effects.

Validation procedure

- Generate controlled access with each client family.
- Confirm FileAccessed and UserAgent values in raw records.
- Verify OfficeId and resource fields are populated.
- Review historical matches with application owners.

TEST CASES

CASE	EXPECTED RESULT
Controlled Python request to a test file	Expected match when audit UserAgent preserves python-requests/.
Normal browser file access	No match.
Approved PowerShell integration	Match and classify as owned benign activity.
Custom or browser-spoofed UserAgent	Expected miss; document coverage gap.

Hunting Initial query	Candidate Current status	Production Measured precision	Optimized Stable feedback
---------------------------------	------------------------------------	---	-------------------------------------

Success

Controlled events match with complete context and legitimate automation is separable by durable ownership attributes.

Rejection

UserAgent is not retained or benign automation cannot be separated without broad exclusions.

Failure

OfficeActivity lacks SharePoint/ OneDrive FileAccessed coverage.



ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	COVERAGE STATEMENT
T1213.002	Data from Information Repositories: SharePoint	Directly covers access to SharePoint or OneDrive content through scripting clients used for programmatic collection.

Detection coverage summary

Strong for the named client families when audit telemetry preserves UserAgent; weak for browser impersonation, custom clients and missing audit events.

Residual risk

Token theft, file sensitivity, bytes transferred and exfiltration require identity, audit, DLP and network evidence beyond this event.

ANALYST CONCLUSION

A high-value hunt with an explicit exfiltration boundary.

Primary GTIG evidence and Microsoft-documented fields support a precise Sentinel hunt. It remains an untested implementation sketch until controlled access confirms UserAgent retention and the tenant proves that approved automation can be separated using stable ownership context.

REFERENCES

- 1. Google Threat Intelligence Group / Mandiant, "UNC6671 Rebrands," 6 August 2026. <https://cloud.google.com/blog/topics/threat-intelligence/unc6671-targets-financial-services-and-enterprise-cloud-environments>
- 2. Microsoft Learn, "OfficeActivity," last updated 27 July 2026. <https://learn.microsoft.com/en-us/azure/azure-monitor/reference/tables/officeactivity>
- 3. Microsoft Learn, "Audit log activities - File and page activities," accessed 8 August 2026. <https://learn.microsoft.com/en-us/purview/audit-log-activities>
- 4. MITRE ATT&CK, T1213.002. <https://attack.mitre.org/techniques/T1213/002/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v1.0	08 August 2026	Hunting	Detection Engineering

Publication control

Eight A4 pages. URLs are defanged. No customer data, credentials, HTML source or rendering assets are included in the public repository.